

OPERATION JUNIOR CYBERSECURITY ANALYST [PROJECT]

BY AFOLARIN JAMES ANTHONY

Final Capstone Technical Report

Submitted for



TECH REGION AFRICA

Cybersecurity Department Cohort: Zero to Defender (Beginner)

PROJECT OVERVIEW

In this capstone, I will act as a Junior Cybersecurity Analyst for a growing company. I have been notified of unusual activity on the network.

My objective is to perform a full security sweep, from initial scanning to traffic analysis and log investigation, and present a professional report on your findings.

Phase 1: Perimeter Reconnaissance (Network Discovery)

Tools used:

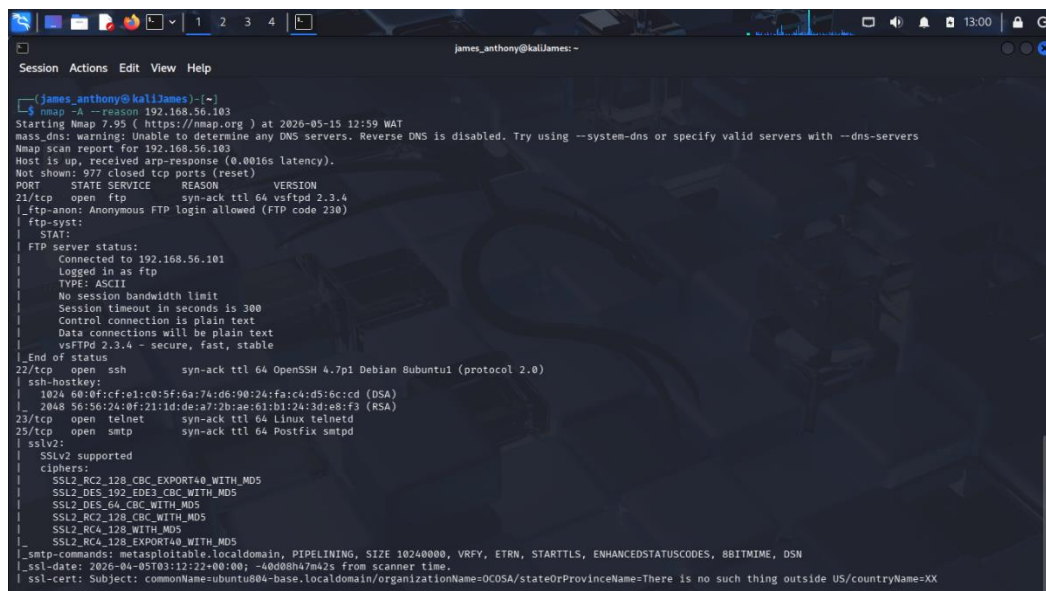
- Kali Linux
- Network Mapper (Nmap)

Target: "Metasploitable 2"

Task: Using Nmap to perform a scan of our target "Metasploitable 2".

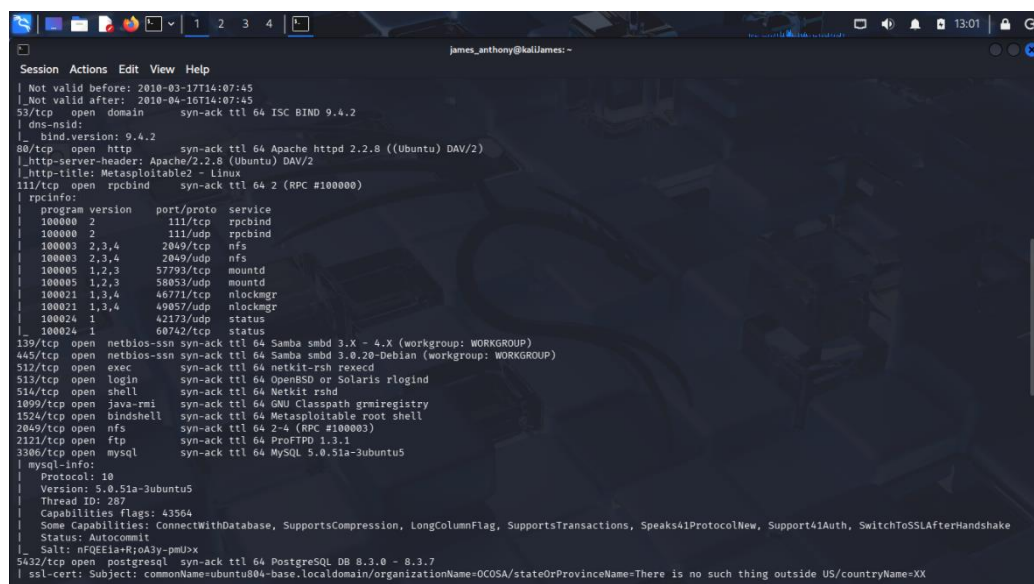
Objective: To identify all open ports and the services running on them.

Requirement: Document at least three open ports (e.g., 22 for SSH, 80 for HTTP, 21 for FTP). For each port, write one sentence explaining why a "Junior Analyst" should monitor it closely.



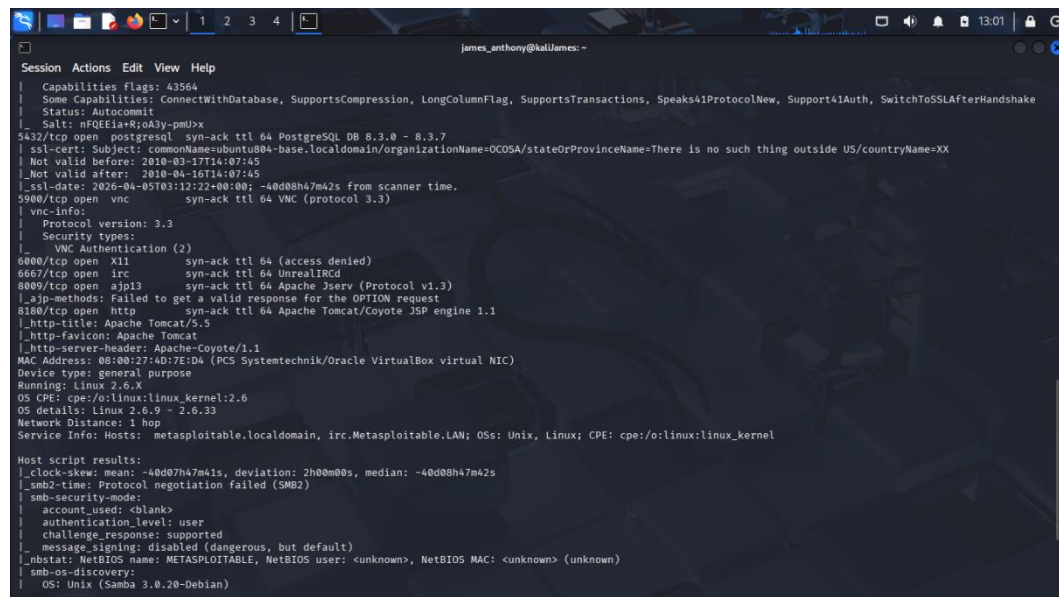
```
james_anthony@kali:~$ nmap -A --reason 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 12:59 WAT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.103
Host is up, received arp-response (0.0016s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        REASON      VERSION
21/tcp    open  ftp             syn-ack ttl 64 vsftpd 2.3.4
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.101
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
22/tcp    open  ssh             syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|   1024 6010:cf:el:c0:5f:6a:74:d6:98:26:fa:c4:d5:6c:cd (DSA)
|   2048 36:36:24:a0:21:1f:de:a7:2b:aec:61:d1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet          syn-ack ttl 64 Linux telnetd
25/tcp    open  smtp            syn-ack ttl 64 Postfix smtpd
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ ssl-date: 2026-05-15T12:59:12Z+0000; -d0d0b047mk2s from scanner time,
|_ ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
```

Fig 1.1



```
james_anthony@kali:~$ nmap -A --reason 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 12:59 WAT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.103
Host is up, received arp-response (0.0016s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        REASON      VERSION
21/tcp    open  ftp             syn-ack ttl 64 vsftpd 2.3.4
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.101
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
22/tcp    open  ssh             syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|   1024 6010:cf:el:c0:5f:6a:74:d6:98:26:fa:c4:d5:6c:cd (DSA)
|   2048 36:36:24:a0:21:1f:de:a7:2b:aec:61:d1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet          syn-ack ttl 64 Linux telnetd
25/tcp    open  smtp            syn-ack ttl 64 Postfix smtpd
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ ssl-date: 2026-05-15T12:59:12Z+0000; -d0d0b047mk2s from scanner time,
|_ ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
```

Fig 1.2



```
Session Actions Edit View Help
| Capabilities Flags: 42564
| Some Capabilities: ConnectWithDatabase, SupportsCompression, LongColumnFlag, SupportsTransactions, Speaks41ProtocolNew, Support41Auth, SwitchToSSLAfterHandshake
| Status: Autocommit
| Salt: nFQEEiaR;0A3y-pmUx
5432/tcp open  postgresql syn-ack ttl 64 PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=OCDSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
| Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-04-05T03:12:22+00:00; -40d08h47m42s from scanner time.
5900/tcp open  vnc syn-ack ttl 64 VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open  X11 syn-ack ttl 64 (access denied)
6667/tcp open  irc syn-ack ttl 64 UnrealIRCd
8009/tcp open  ajp13 syn-ack ttl 64 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTIONS request
8180/tcp open  http syn-ack ttl 64 Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
MAC Address: 08:00:27:4D:7E:D4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_clock-skew: mean: -40d07h47m41s, deviation: 2h00m00s, median: -40d08h47m42s
|_smb2-times: Protocol negotiation failed (SMB2)
|_smb-security-mode:
| account_used: <blank>
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
```

Fig 1.3

Fig 1.1, 1.2 & 1.3 show Nmap scan report of Metasploitable 2

Documentation:

Using Network Mapper (NMAP), I was able to uncover that the target, Metasploitable 2 had up to 23 ports opened and listening for connections at once. While it could be seen as normal activity to the untrained eye, it serves as a potential risk for attackers to exploit.

Some ports and services running that I was keen to monitor closely as a junior cybersecurity analyst were;

1. Port 23 (Telnet) – This service running on this port gives remote access unencrypted access to our host target which attackers can exploit.
2. Port 445(NetBIOS ssn) – This service is an older protocol used for file/printer sharing between computers in a network and if it is accessible by the internet, it makes the computers vulnerable to a “worm” malware.
3. Port 22 (SSH) – This provide encrypted remote access to our target, but is it prone to brute force attack.
4. Port 80 (HTTP) – This service is known to transport inputted data (mostly users’ credential) in an unencrypted format which can be seen and read by anyone including attackers.
5. Port 21 (FTP) – This file sharing service also shares data in plain text which can be sniffed and/or eavesdropped on.

Phase 2: Network Traffic Analysis (The Investigation)

Tools used:

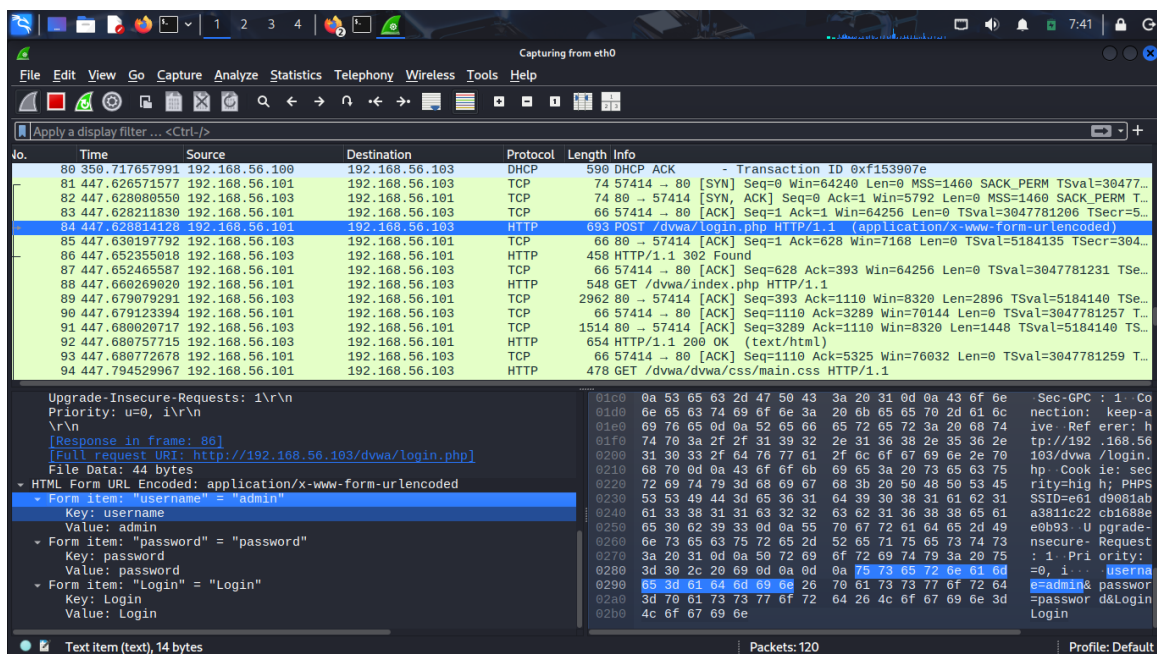
- Wireshark
- Damn Vulnerable Web Application (DVWA) [Metasploitable 2's IP]

Task:

Launch **Wireshark** and begin a live capture. While the capture is running, navigate to the target's web interface (DVWA) and perform a login attempt.

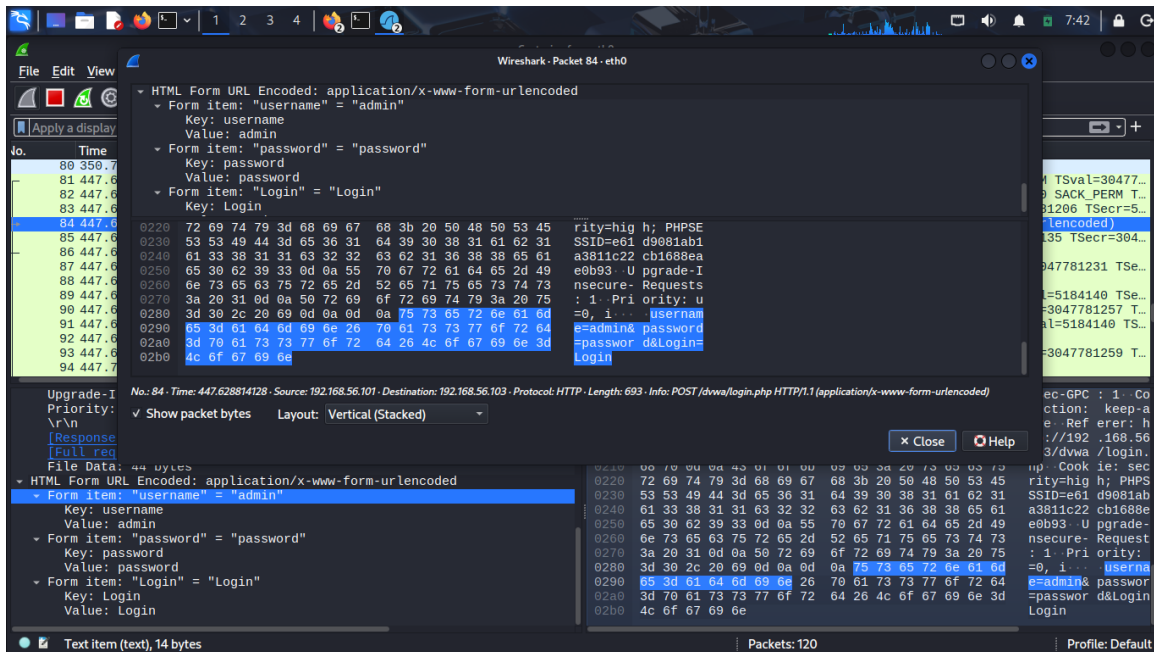
Objective: Filter the traffic to find the specific protocol used (HTTP/TCP).

Requirement: Locate the "POST" request in the packet list. Find the credentials (username/password) you just entered in the packet details. Provide a screenshot as evidence of how "Insecure Traffic" exposes user data.



The highlighted packet (packet 84) is the "POST" request packet

Fig 2.1



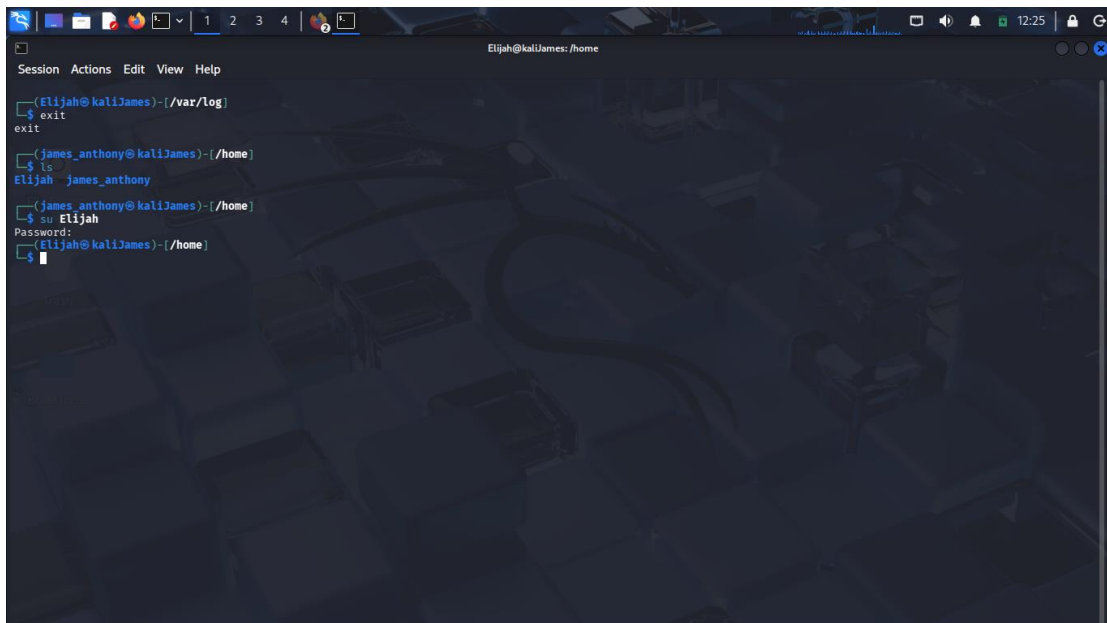
The credentials inputted in the website is shown here in wireshark In plain text.

fig 2.2

The credentials shown in plain text is a clear red flag which compromises confidentiality. The plain text shown is because the web application interacted with uses the unsecure and unencrypted “http” protocol. Anyone most especially attackers, will be able to see traffic and privileged information that should be kept secret. As a junior cybersecurity analyst, I strongly recommend the “https” protocol to be used as it is a secured and encryption version of “http”.

Phase 3: System Log & Permission Audit (Linux Operations)

- **Tools used:**
 - Linux Operating System
- **The Task:** Access the Linux terminal of your investigative machine. Create a new administrative user for yourself.
- **Objective:** Navigate to the `/var/log` directory. You will notice that certain files require elevated privileges to read.
- **Junior Analyst Requirement:** Use the `sudo` command to access the authentication logs (`auth.log`). Use the `grep` command to search for "failed" login attempts. Record the IP address that was attempting to gain unauthorized access.

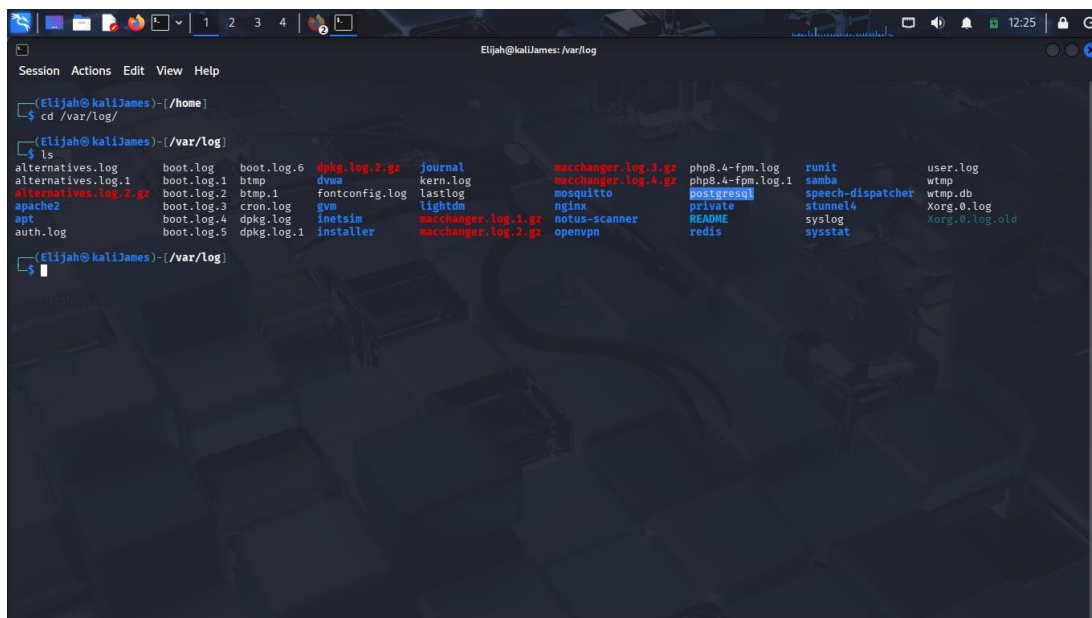


```
Session Actions Edit View Help
Elijah@kaliJames: /home

(Elijah@kaliJames)-[/var/log]
$ exit
exit
(james_anthony@kaliJames)-[/home]
$ ls
Elijah james_anthony
(james_anthony@kaliJames)-[/home]
$ su Elijah
Password:
(Elijah@kaliJames)-[/home]
```

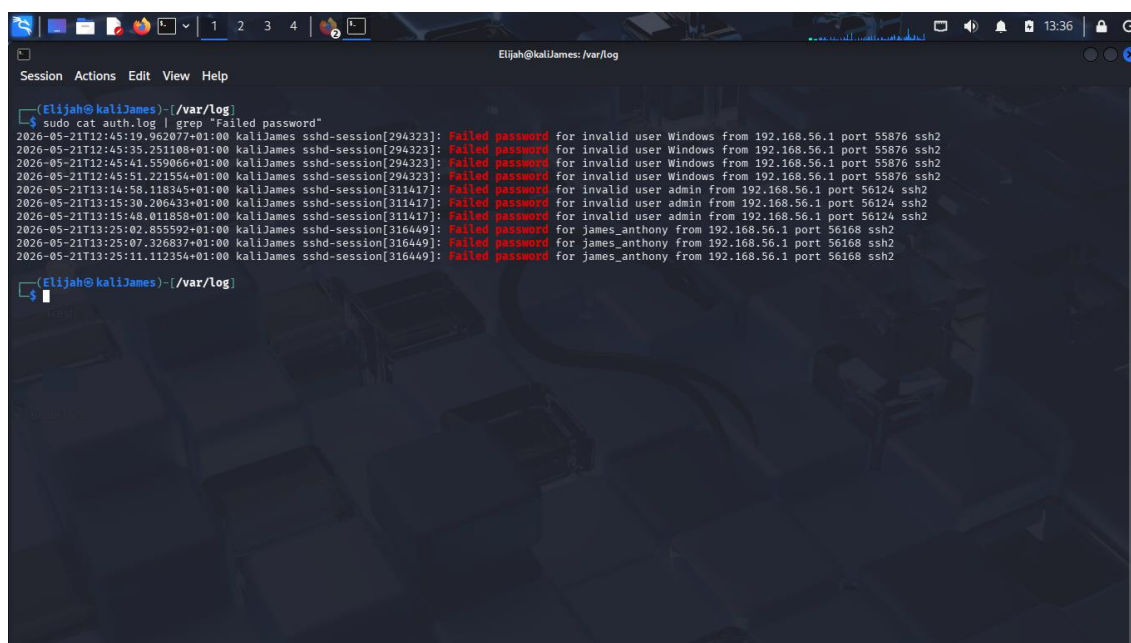
The new administrative user has been created

fig 3.1



Here is a list of files, directories in the /var/log directory
Auth.log can be seen

fig 3.2



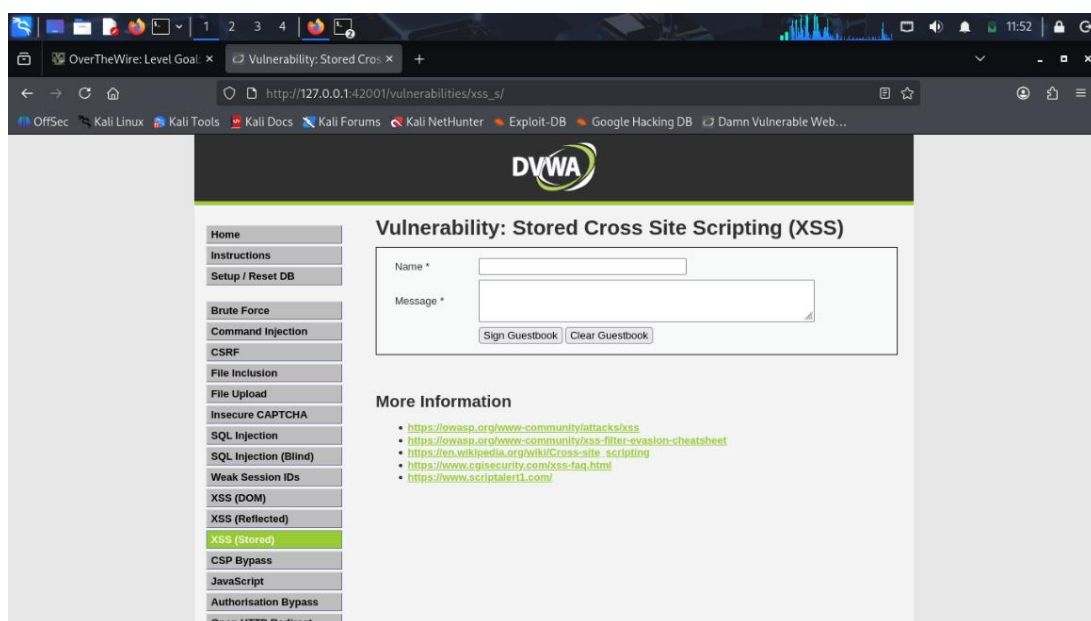
Auth.log opened with administrative privileges
The “grep” command was used to filter the logs
and the culprit has been discovered.

fig 3.2

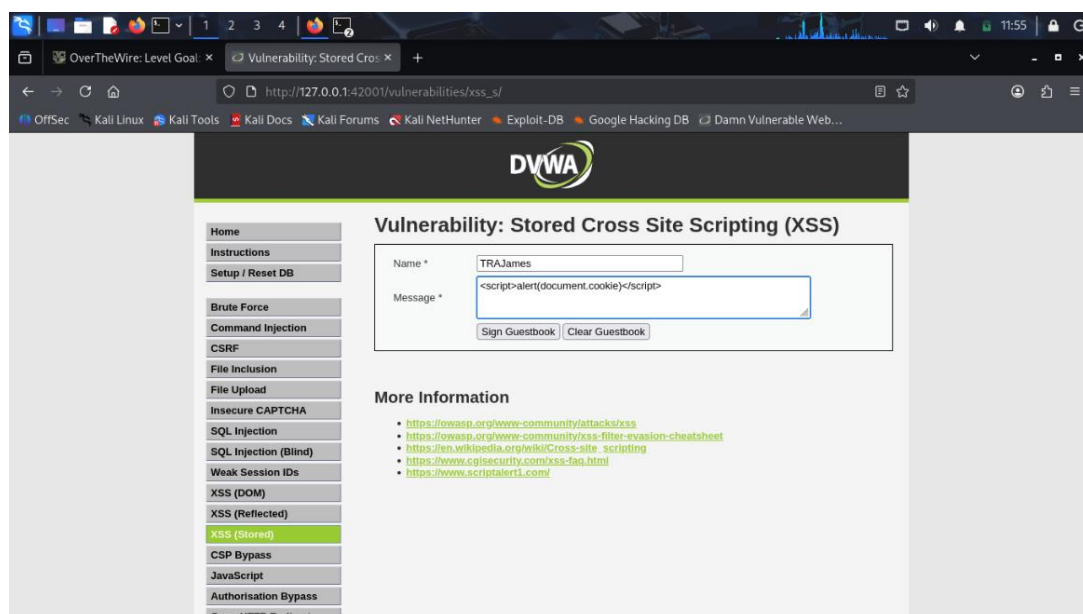
The culprit of the “Failed password” can be known by the Ip address “192.168.56.1”.

Phase 4: Web Application Vulnerability Assessment

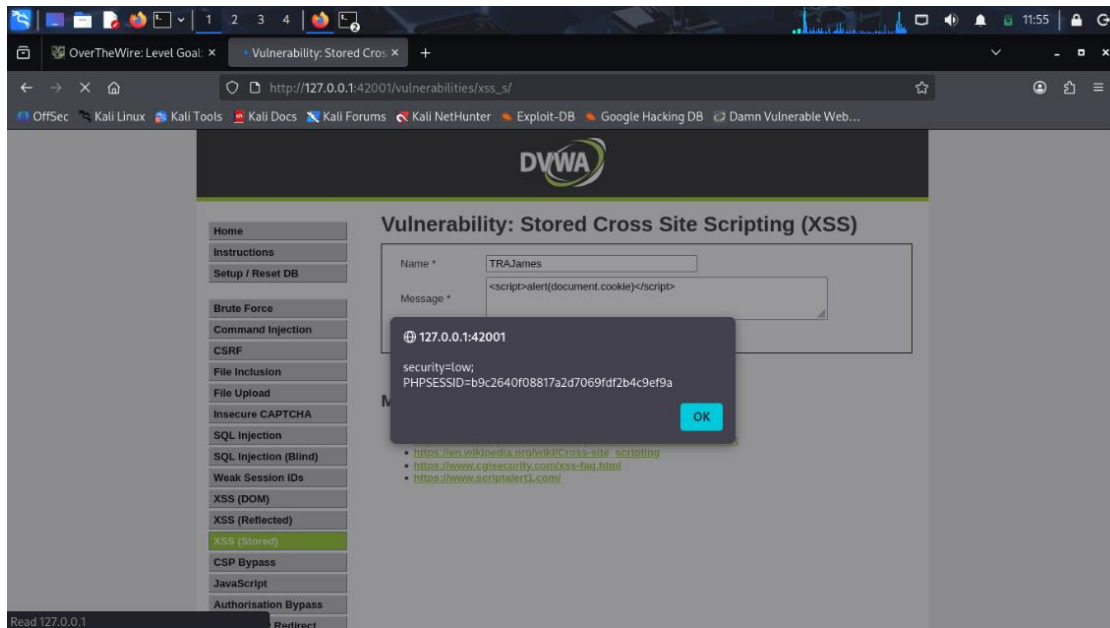
- **The Task:** Log into the **DVWA** (Damn Vulnerable Web Application) and set the security level to "Low"
- **Objective:** Perform a basic SQL Injection or Cross-Site Scripting (XSS) attack to see how a web server reacts to malicious input.
- **Junior Analyst Requirement:** Map your discovery to the **OWASP Top 10** categories. Briefly explain how this vulnerability violates the "Integrity" or "Confidentiality" of the company's data.



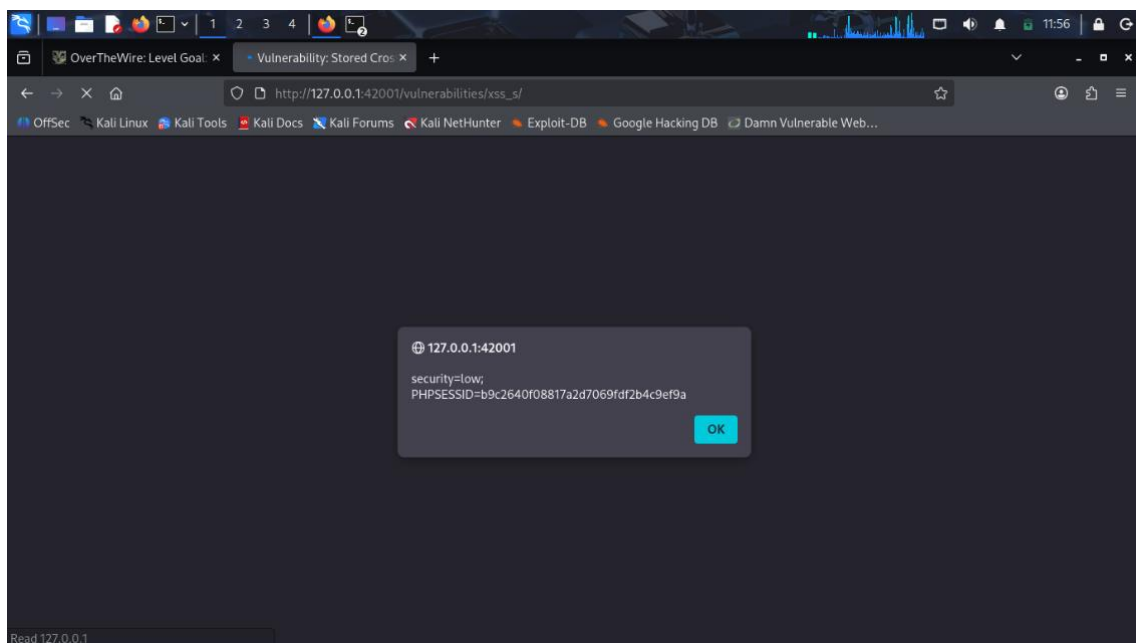
*The XSS STORED tab of the DVWA web application
fig 4.1*



*The malicious script being inputted in the "message" placeholder
fig 4.2*



*The malicious script has been executed successfully even at the server's side.
Fig 4.3*



*As long as the malicious code remains in the server, any user at anytime
will have the alerts and their session cookie exposed to attackers
leading to impersonation.
fig 4.4*

Phase 5: Mitigation & Final Technical Report

- **The Task:** Summarize your findings into a single PDF document.
- **Objective:** Move from "finding problems" to "solving problems."
- **Junior Analyst Requirement:** For every issue found in Phases 1 - 4, provide one professional recommendation.
 - *Example:* If you found cleartext passwords in Phase 2, your recommendation should explain how **Hashing** or **Encryption (HTTPS)** would solve the problem.

Professional Recommendation for each phase;

Phase 1: My professional recommendation is to ensure that

- All unnecessary and used ports should be closed.
- Any port that should be run should not run outdated and unpatched services. Make sure that the services are up to date.
- Ensure to use services that support encryption to prevent sensitive data from being revealed in plaintext and exploited by attackers.

Phase 2: My professional recommendation;

- Ensure that all web traffic should be done through the (HTTPS) 443 port which supports encryption of the web traffic protecting credentials, sensitive data from packet sniffers.
- Ensure that websites visited have verified SSL certificates.

Phase 3: My professional recommendation;

- Ensure to use the **principle of least privileged** to ensure that users on a system are only allowed to perform limited and necessary actions (authorization).
- Make sure to take note and perform proper investigation into the culprit of the “Failed passwords” if it’s someone who forgot password or it’s a brute - force attack in which case SOC analysts are to take proper precautions.

Phase 4: My professional recommendation;

To prevent XSS attacks and XSS dependencies vulnerabilities;

- Web developers should make sure that web servers should only accept input as text alone and not as commands to avoid execution.
- Developers should set cookies to be tagged with the “Secure” tag. This will ensure that even if a cookie was stolen, it can’t be read as it is encrypted.
- Configurations should be given to the backend to restrict JavaScript and other similar resources from reading the cookie.

This is a list of my recommendations as a Junior Cybersecurity Analyst for the issues.

Thank you.